

Guía Metodológica Detallada

Encuesta CAASM – Gestión de la Superficie de Ataque de Activos Cibernéticos

1. Objetivo de la encuesta

La encuesta tiene como misión medir, de forma estructurada y comparable, el grado de adopción, madurez y efectividad de capacidades de **Cyber Asset Attack Surface Management (CAASM)** en organizaciones españolas, con referencia a:

- Tendencias internacionales en gestión de superficie de ataque y exposición.
- Marcos regulatorios europeos y nacionales (NIS2, ENS, GDPR, DORA, ISO 27001, NIST, etc.).
- Prácticas emergentes de visibilidad, priorización basada en riesgo y remediación continua.

El propósito no es “examinar” a las organizaciones, sino ayudarlas a situarse en un mapa de madurez y orientar decisiones de inversión, priorización y gobernanza.

2. Población objetivo y muestra

2.1 Población objetivo

- Organizaciones de sectores esenciales y importantes definidos por NIS2 (energía, transporte, banca, sanidad, agua, administración pública, etc.).
- Organizaciones con elevado peso digital (servicios digitales, telecomunicaciones, TIC, educación superior, investigación).
- Proveedores de servicios críticos (cloud, outsourcing, servicios de seguridad gestionada, etc.).

2.2 Perfiles de respuesta

Se recomienda que cada cuestionario sea respondido por:

- CISO / responsable máximo de ciberseguridad, o
- Responsable de riesgo tecnológico / continuidad, o
- Responsable de infraestructura / operaciones con visión transversal.

En organizaciones grandes, se sugiere un enfoque multinivel (respuesta corporativa + complementos por unidad de negocio o país, si procede).

3. Estructura de la encuesta

La encuesta se estructura en siete bloques:

1. Datos generales de la organización.
2. Visibilidad y cobertura de activos.
3. Higiene de seguridad y controles.
4. Exposición y riesgo material.
5. Remediación, automatización y resiliencia.
6. Cumplimiento regulatorio y reporting.
7. Gobernanza, estrategia y cultura.

Cada bloque combina:

- Preguntas cerradas tipo Likert (4 o más opciones, deliberadamente sin “neutral” cómodo).
- Preguntas de selección múltiple para caracterizar capacidades y herramientas.
- Una pequeña dosis de preguntas abiertas para capturar matices y color local.

4. Lógica de diseño de las preguntas

4.1 Sin “neutrales acogedores”

Se evita la opción “ni bueno ni malo” para fomentar una toma de postura. La redacción introduce un tono ligero e irónico en algunas opciones (“esperanza como estrategia”, “fauna tecnológica inédita”) con dos objetivos:

- Invitar a una auto-reflexión honesta sin caer en tecnicismos vacíos.
- Hacer más memorable la experiencia de respuesta, facilitando el debate posterior.

La ironía, eso sí, está siempre al servicio de un propósito constructivo: ayudar a ver la distancia entre la aspiración y la realidad.

4.2 Cobertura integral de dominios

Las preguntas se han diseñado para cubrir:

- Activos TI tradicionales.
- Entornos de nube (IaaS, PaaS, SaaS).
- APIs y servicios web.
- OT / entornos industriales (cuando apliquen).
- Identidades, privilegios y accesos.
- Procesos, herramientas y governance.

El objetivo es reflejar la **superficie de ataque completa**, no sólo servidores y endpoints.

4.3 Madurez y capacidad, no sólo existencia

En lugar de preguntar únicamente “¿tiene usted X?”, se explora:

- Grado de integración y automatización.
- Frecuencia de actualización y revisión.
- Uso real en procesos de decisión (riesgos, inversiones, cumplimiento).
- Conexión con la estrategia de Zero Trust y resiliencia.

Así se distingue entre capacidades decorativas y capacidades efectivamente operativas.

5. Escalas de respuesta y codificación

Para explotación cuantitativa, se sugiere codificar las respuestas en escalas numéricas, manteniendo el texto original como referencia.

5.1 Ejemplo de codificación

Para una pregunta tipo:

“Tiempo medio de mitigación de exposiciones críticas”

- Menos de 7 días → 4
- Entre 7 y 30 días → 3
- Entre 1 y 3 meses → 2
- Más de 3 meses / indefinido → 1

La escala (1–4) se interpreta como: 1 = inmadurez, 4 = buena práctica.

Para opciones con tono irónico, se mantiene el valor numérico coherente con la madurez, no con la gracia de la redacción.

6. Indicadores derivados y agregación

A partir de las respuestas pueden construirse diversos indicadores, por ejemplo:

6.1 Ítems básicos

- Índice de visibilidad de activos (IVA).
- Índice de higiene y controles (IHC).
- Índice de exposición y priorización (IEP).
- Índice de remediación y automatización (IRA).
- Índice de cumplimiento y reporting (ICR).
- Índice de gobernanza y cultura (IGC).

Cada índice se obtiene como media normalizada de las respuestas asociadas a su bloque.

6.2 Índice Global de Madurez (IGM)

El IGM combina los índices anteriores ponderando su relevancia. Un esquema simple podría ser:

- IVA: 20 %
- IHC: 20 %
- IEP: 20 %
- IRA: 20 %
- ICR: 10 %
- IGC: 10 %

La plantilla de Excel propuesta en otro documento detalla fórmulas y pesos ajustables.

7. Comparabilidad y benchmarking

7.1 Comparaciones internas

- Entre unidades de negocio o filiales.
- Entre sectores dentro de la misma organización (TI vs OT, por ejemplo).
- Entre años, en encuestas repetidas (tendencia de madurez).

7.2 Comparaciones externas

- Por sector (sanidad, energía, administración, etc.).
- Por tamaño de organización.
- Por grado de exposición internacional.

Es esencial anonimizar datos cuando se compartan resultados a nivel agregado, especialmente si se pretende alimentar observatorios sectoriales o nacionales.

8. Calidad de datos y sesgos

8.1 Riesgo de optimismo tecnológico

Las respuestas tienden a presentar la organización en un tono algo más favorable. Para mitigar este sesgo:

- Recomendar el contraste previo de datos internos (inventarios, tiempos de remediación, etc.).
- Fomentar la participación de varios roles en la respuesta (CISO, operaciones, cumplimiento).
- Interpretar los resultados como “percepción informada”, no como auditoría.

8.2 Coherencia entre bloques

En análisis posteriores, conviene cruzar respuestas:

- Altos niveles de madurez declarados en visibilidad vs alta frecuencia de activos “sorpresa”.
- Elevada automatización declarada vs largos tiempos medios de remediación.
- Fuerte uso de CAASM para cumplimiento vs ausencia de mapeos normativos formales.

Estas incoherencias son una oportunidad para el diálogo, no un motivo de sanción.

9. Uso de los resultados

Los resultados pueden emplearse para:

- Orientar planes de mejora (roadmaps CAASM, Zero Trust, NIS2, ENS, etc.).
- Priorizar inversiones (herramientas, automatización, refuerzo de equipos).
- Elaborar informes ejecutivos y dashboards de exposición.
- Apoyar estrategias sectoriales o nacionales de supervisión continua.

Se recomienda acompañar la entrega de resultados con:

- Briefing ejecutivo.
- Taller de interpretación con el equipo de seguridad.
- Propuesta de acciones priorizadas.

10. Frecuencia de aplicación

- Nivel organización individual: cada 12–18 meses.
- Nivel sectorial o nacional: dependerá de la capacidad y objetivos, pero se sugiere un ciclo de 2 años para medir evolución, alineado con informes de amenazas y marcos regulatorios.

Fin de la guía metodológica.